Decision Record DR-2026-027: Customer-managed keys (CMK)

Document control	
Document ID	DR-2026-027
Document type	Decision Record
Date	2026-04-21
Status	Accepted
Meeting	TRBM-2026-04-21
Review IDs	TRB-2026-027
Feature keys	Customer-managed keys (CMK)@Security & Networking
Classification	Internal – Synthetic Sample

> Acme Health Plan is fictional. This is a synthetic sample document for the Databricks Feature Tracker.

Status: Approved · **Approved scope:** PHI · **Decided at:** TRBM-2026-04-21
Review: TRB-2026-027 · **Feature:** `Customer-managed keys (CMK)@Security & Networking` · **Databricks phase at decision:** GA

Context

Information Security selected Customer-Managed Keys (CMK) for encrypting PHI at rest. TRB reviewed key lifecycle, HSM support, and key rotation automation.

Decision

Customer-managed keys are approved and required for all PHI data at rest. Encryption must use CMK; AWS default keys are not acceptable for PHI.

Risks considered

- Key loss disables all encrypted data
- Rotation complexity for multi-region deployments

- KMS authorization bypass

Mitigations relied on

- Keys backed up in AWS KMS secure vault
- Automated rotation via KMS key policy
- KMS access controlled via IAM + UC external locations

Control mappings

- HIPAA-Security-Rule 164.312(a)(2)(ii) (Encryption and decryption): Satisfied
- NIST-800-53-R5 SC-12 (Cryptographic Key Establishment and Management): Satisfied
- HITRUST-CSF 06.a (Cryptography): Satisfied

Re-review

Trigger: Annual re-review · Next review: 2027-04-21